

黑匣子 Cloudflare 网站技术归档

DESIGN REPORT · 2026 / 09 / 26

阅读范围与结论

给接手网站维护的人：这份文档说明网站现在怎样运行、资料放在哪里、一次操作会经过哪些检查，以及发布时要注意什么。内容按 2026 年 9 月 26 日的仓库代码整理；线上环境当天的实际状态没有重新登录核验。

系统构成

单 Worker · D1 元数据 · R2 文件

01 / 章节

一 网站要保存什么

黑匣子网站是校园戏剧社团的资料库。访客可以找作品、演出版本、演职人员和已公开的照片等资料；登录成员可以补充文件；管理员负责审核、整理档案和管理可见范围。

资料之间有一条简单的关系：一部作品可以有多个演出版本；每个版本关联参与的成员和他们的演职工作；照片、剧本、音频等作为资源挂在作品或版本下。这样查询一部剧时，页面能把“哪次演出、谁参与、有哪些资料”放在一起，而不会把不同年份的演出混成一条记录。

网站希望做到三件事：让公开资料容易找到，让新资料经过合适的审核再公开，让维护者知道某份资料 and 文件属于哪里。当前系统部署在 Cloudflare 上，由一个 Worker 处理网站请求。

02 / 章节

二 请求进入网站后发生什么

主站 npubblackbox.online 和后台 admin.npubblackbox.online 都进入同一个 Cloudflare Worker。可以把 Worker 理解为网站的服务器程序：它接收请求、检查身份、查资料，再返回页面或文件。后台域名有额外的管理员门禁，但不是另一台服务器。

入口	同一 Worker 中的处理	数据或结果
主站域名	生成公开页面，处理页面操作	从 D1 读资料；按权限从 R2 读文件
后台域名	先检查管理员身份，再处理管理操作	在 D1 中修改资料和审核状态
静态文件请求	交给 Static Assets	返回 public 中的脚本、样式和图片
定时触发器	执行后台维护任务	清理过期上传、限流记录和导入明细

这里的 D1 是存放结构化资料的数据库，记录作品、成员、文件说明和审核状态；R2 是保存文件内容的对象存储。查一张照片时，网站先用 D1 判断它是什么、能否公开，再从 R2 取出图片。Hono 负责把不同网址交给相应的页面或操作。定时维护任务在每小时第 17 分钟运行，它能清理过期记录，但不能代替备份和人工检查。

03 / 章节

三 页面 数据库和文件各做什么

首页、作品页和资源页由 Worker 直接生成完整 HTML。打开首页时，程序会读取站点资料、公告、焦点内容和最新作品，然后把它们放进页面。样式、浏览器脚本和站点图片属于静态文件，不需要走这套资料查询。页面和后台操作共用身份检查等基础处理，因此修改通用的登录或安全逻辑时，主站与后台都需要检查。

网站直接通过 D1 绑定执行 SQL 查询，没有单独运行一个数据库服务器，也没有传统数据库连接池。R2 只负责保存文件字节，不承担“这个文件是否能看”的判断。把说明和权限放在 D1、把大文件放在 R2，能让查询和下载各做各的事；代价是两边的写入无法合成一次数据库事务，失败清理需要另做处理。

04 / 章节

四 三种常见操作怎样走完

访客浏览作品和资源

访客从作品列表进入详情页后，网站先检查作品是否公开，再显示演出版本、参与者和已批准的资源。隐藏作品只有管理员能看，它下面的资源也不会因拥有文件地址而对其他人开放。

已批准资源的列表和预览可以对访客开放；完整资料页和文件下载要求登录。下载时，网站先检查资源状态、关联作品和当前用户的权限，确认可以访问后才读取 R2。文件返回时还会设置合适的类型、下载方式和缓存规则。

想做什么	网站先做什么	最后得到什么
看作品详情	检查作品可见性，再读取版本、演职记录和已批准资源	作品页面
下载资源文件	检查资源、所属作品和登录权限，再读取 R2	文件内容

成员上传新资料

投稿者先登录，再选择资料类型和所属作品。网站会检查文件大小、类型、版本关系及同时进行的上传任务数，并为这次上传预留空间。上传任务最长保留 24 小时。通常由 Worker 分片接收文件并写入 R2；代码也支持在配齐 R2 直传凭据时使用直传，但目前无法从仓库确认线上是否启用了这一路径。

文件传完后，网站合并对象，在 D1 中建立资源记录，再决定是否需要管理员审核。管理员或符合现有低风险规则的成员投稿可自动批准，其余投稿会等待审核。文件进入 R2 不等于已经公开：访客只能看到获批准且所属作品可见的资源。失败上传留下的文件会进入后续清理流程。

阶段	网站做什么	访客能否看到
创建任务	检查身份和文件规则，预留空间	不能
传输文件	分片写入 R2，完成后合并	不能
建立记录与审核	写入 D1，确定审核状态	获批准且所属作品可见后才能看到

管理员批量导入演职记录

管理员上传表格后会先看到预览，确认匹配结果再正式导入。表格有列数、行数和文件大小限制。确认导入时，相关数据库操作作为一批执行，避免只写入一部分演职关系；受保护的撤销流程也按批次处理。历史发布记录显示这项功能已随 V3.5 发布，但这次整理文档时没有重新登录线上后台做实际导入。

05 / 章节

五 资料 and 文件怎样保存

D1 保存账号、成员、作品、演出版本、演职记录、资源说明、上传任务和审核记录。仓库用编号迁移文件管理数据库结构，目前共有 19 个迁移，最新编号为 0019。发布前需要检查生产数据库应用到哪一步，先备份，再执行尚未应用的迁移；本地数据库更新并不会自动更新生产数据库。

R2 保存图片、剧本、音频等文件。目前视频上传关闭。照片上限为 20 MiB，剧本为 50 MiB，音频及其他文件为 100 MiB，单个上传分片为 50 MiB。网站还设置了约 9 GB 的软件预算，用已存文件和预留空间计算；这不是 R2 桶的实际容量上限。

D1 与 R2 不能一起提交或一起回滚。上传完成时，网站先处理文件，再写资料记录；如果某一步失败，会登记待清理的文件并由后续任务重试删除。这能减少“数据库里找不到、桶里还留着”的文件，但仍要保证清理任务正常运行。图片在边缘可能短期缓存以减少重复读取，不过每次访问仍先经过资料和权限检查。

现有生产备份命令只导出 D1 的 SQL 数据，不包含 R2 文件。因此这份备份不能单独恢复一个完整的网站。接手维护时，应另外安排 R2 文件备份，并实际演练一次恢复。

06 / 章节

六 谁可以看和修改

登录后，浏览器会保存一个带签名的会话 Cookie。签名用于检查凭据有没有被改动；网站还会查询 D1，确认账号仍然有效。会话有效期为 14 天。密码以 scrypt 方式保存，同时保留对历史密码格式的验证能力。

网站按操作检查权限，而不只是区分“已登录”和“未登录”。访客可以浏览公开内容；成员可以按规则投稿、查看和下载；管理员还可以审核、管理隐藏作品和批量导入。后台域名增加了入口检查，但真正的权限仍由每个操作的服务端逻辑决定。

写入操作会检查请求是否来自本站，并核对 CSRF 令牌，防止其他网站借用已登录浏览器发起修改。页面还限制嵌入和脚本来源，敏感响应不会让浏览器随意缓存。生产配置启用了 Turnstile 挑战，但它只用于注册、匿名反馈等指定流程。网站也会对部分频繁请求限流。

07 / 章节

七 怎样启动 发布和检查

本地开发需要 Node.js 24 或更新版本。安装依赖后，运行 `npm run db:init` 建立本地 D1，再运行 `npm run dev` 启动网站。本地使用独立的 D1 与 R2 资源；本地能运行，不代表生产资源和密钥已经配置正确。

生产发布需要主动执行，`git push` 不会自动把网站上线。常用顺序是：

1. `npm run deploy:check`：检查格式、类型、后端测试和生产构建；这一步不会发布。
2. `npm run db:production:backup`：导出生产 D1 数据。
3. `npm run db:production:migrate`：应用生产数据库迁移。

4. `npm run deploy`: 发布 Worker。

5. `npm run smoke:production`: 检查九个公开地址能否基本正常响应。

最后一步只能发现公开页面或接口的明显故障，不能代替登录、上传、审核和后台导入的人工验收。生产环境需要会话密钥和 Turnstile 密钥；仓库只声明需要它们，不保存密钥内容。系统会记录请求编号、路由、状态和总耗时，但没有逐条数据库查询耗时，不能单凭现有日志判断哪个查询最慢。

仓库中最近一次有记录的生产验证发生在 2026 年 9 月 23 日。那是当时的发布记录，不代表 9 月 27 日线上仍是同一版本。本次只整理仓库文档，没有重新登录 Cloudflare 控制台检查当前部署。

08 / 章节

八 接下来需要留意什么

目前不能上传视频。R2 直传代码存在，线上是否启用还需检查环境密钥。D1 备份没有覆盖 R2 文件，完整恢复流程仍需补齐。线上权限、上传、后台导入和恢复操作也需要再做一次实际验收。

还没有可靠资料说明最初为什么选择这套 Cloudflare 组合，也没有完整记录每条自动审核规则当时的业务考虑。接手维护时，可以先按本文理解现有行为；如果要修改这些规则，应与负责内容审核的人确认需求，再更新代码和文档。